

Introduction

This document looks at the ethical and legal issues that our group needed to think about when building the AI Failure Museum. The application is a Django-based website that lets users browse case studies about AI systems that have gone wrong in environmental or geospatial contexts. We've gone through five key areas: privacy and GDPR, gamification, misinformation, accessibility, and security. At the end, we explain whether we think formal ethics approval is needed.

1. Privacy, GDPR, and Data Minimisation

What law applies?

Because we are based at a UK university, our application has to follow the UK General Data Protection Regulation (UK GDPR) and the Data Protection Act 2018. These laws control how we collect, store, and use personal information from our users.

What data do we collect?

We have tried to keep data collection as small as possible. The only personal data we store is:

- A username or display name (users can choose a pseudonym, they do not have to use their real name).
- An email address, used only for account registration and password resets.
- A password that has been hashed. Django takes care of this automatically by using PBKDF2 hashing, so we never store passwords in plain text.
- Their job in the system (visitor or curator), which is necessary for controlling access.
- Quiz scores and completed quizzes, which are used for the points and badge system.
- Session cookies, which keep the user logged in during their visit.

We don't ask for any financial information, location data, or any of the sensitive types of information outlined in UK GDPR Article 9, such health data or political beliefs. We don't utilise any third-party analytics software, like Google Analytics, either.

How can users delete their data?

The standard says that there must be a simple "delete my data" feature. This has been added to the account settings page. When someone deletes their account, all of their personal information, like their username, email address, and quiz history, is permanently deleted from the database. We only

keep anonymous aggregate statistics, such the total number of exhibit views, because these can't be traced back to a single person.

Privacy policy

You don't have to log in to see our privacy policy on the internet. It tells users in simple terms what we collect, why we collect it, and what their rights are under UK GDPR. This is a requirement of Articles 13 and 14 of the regulation.

.

2. Acceptable Use and Safety of Gamification

How we've designed it

The specification says gamification should be lightweight and appropriate for a university setting. We award points and badges when users complete reflective quizzes attached to exhibits. We deliberately chose not to award points just for viewing pages, because that would encourage shallow engagement without any learning.

Risks we thought about

- **Compulsive use:** We have not included any streak mechanics, time-limited events, or 'you'll lose your progress' warnings. These features are common in commercial apps but can create unhealthy pressure. Our system has none of them.
- **Unfair competition:** If we create a leaderSSboard, it will just show display names, not real names, so people won't be rated in a way that could make them feel bad.
- **Discouraging struggling learners:** Badges are awarded for completing a quiz, not for getting every answer right. This means users who find the content difficult are not penalised.
- **Inappropriate content in rewards:** The names and descriptions of all the badges are written in formal, academic language. Nothing is petty or insensitive because the topic is so serious (real-world AI failures).

3. Risks of Misinformation and Misleading Claims

What's the risk?

The museum presents realistic-sounding case studies of AI failures. People might think that these are reports about genuine businesses or systems, which could be unjust to those businesses or propagate false information.

How we're managing it

- There is a prominent sign at the top of each exhibit page that says that the case study is made up and meant to show how things work, not a true story about a real organization.
- We do not name any real companies, government bodies, or individuals in our exhibits. Any similarity to real systems is coincidental.
- The 'Contributing Factors' section of each exhibit separates technical issues, data problems, and governance failures, we avoid just blaming one party.
- Curators have to review and approve every exhibit before it goes live, which gives us a moderation layer.
- We've written our own case studies as a team. We have not used AI tools to generate exhibit content, in line with the AI-minimal requirement for this module.
- Quizzes ask students to reflect on uncertainty and bias in AI outputs, which directly models responsible thinking about AI, the opposite of spreading misinformation.

4. Accessibility and Inclusion

Our target standard

We are aiming to meet WCAG 2.1 Level AA, which is the standard required for public sector websites in the UK under the Public Sector Bodies Accessibility Regulations 2018. Although we are a student project, we think it's good practice to aim for this standard, and it is also mentioned as a requirement in the specification.

What we've done

- We use semantic HTML5 elements (like `<h1>`, `<h2>`, and `<h3>`) so that screen readers can navigate the page properly.
- All images and diagrams have alt text descriptions.
- Colour contrast meets WCAG 2.1 AA minimums (at least 4.5:1 for normal text).
- We never use colour alone to convey meaning, for example, error messages include text, not just a red border.
- The whole site can be used with just a keyboard, no mouse required.

- Font sizes are in relative units (rem) so that users who have changed their browser's default font size are not affected.
- The design is mobile-first and responsive.

Inclusion in our content

We've tried to choose a range of geographic and sectoral contexts for our exhibits, so the museum doesn't present AI failure as a problem only in one country or industry. Exhibit text is written to be readable at undergraduate level without assuming specialist technical knowledge.

How we'll test it

We will test accessibility using the Axe browser extension for automated checks, manual keyboard navigation testing, and the NVDA screen reader on Windows. Results will be documented for our CW2 submission.

5. Security Controls

Authentication

We use Django's built-in authentication mechanism, which hashes passwords with SHA-256 and PBKDF2. People sign in with a password and a username. Django's CSRF middleware protects sessions by stopping cross-site request forgery attacks on all forms.

Role-based access control

We have three user roles:

- **Visitors** can browse exhibits, complete quizzes, and bookmark case studies. They cannot create or edit content.
- **Curators** can create, edit, and archive exhibits and upload supporting artefacts. They can also view basic engagement analytics.
- **Developers/Admins** have full access to the Django admin panel for system maintenance.

All of these checks happen on the server using Django's `@login_required` and

`@permission_required` decorators. There is no way to access curator functions just by changing a URL.

Secrets management

- Django's SECRET_KEY is stored in a .env file that is listed in .git ignore, it has never been committed to GitHub.
- We have a .env.example file in the repository that shows which environment variables are needed, without including any real values.
- Any API keys or database passwords are managed the same way.
- We've checked the commit history to make sure nothing sensitive has been accidentally pushed.

Other security measures

- DEBUG is set to False in the production environment.
- Django's built-in protections against SQL injection, XSS, and clickjacking are all active.
- File uploads (for exhibit artefacts) are validated server-side. Only specific MIME types are accepted.
- The application runs over HTTPS in production.

6. Conclusion: Is Ethics Approval Needed?

Based on everything we've covered above, we do not think formal ethics committee approval is required for this project. Our reasons are:

- We are not carrying out research on human participants. Users of the website are just using an application, not taking part in a study.
- We do not collect any of the sensitive personal data categories listed under UK GDPR Article 9(such as health data, political opinions, or biometric data).
- Our gamification features are minimal and educational, there is no commercial incentive or addictive design.
- Case studies are clearly labelled as fictionalised, and no real individuals or organisations are named in a harmful way.
- We have appropriate security and privacy mitigations in place.

In Summary, we don't think this endeavour needs official ethics approval. The system merely collects basic account information, doesn't entail research on people, and doesn't seem to pose any significant risks of harm. We will look at this assessment again when we turn in our CW2, especially if the project's scope changes in Sprint 2.